SISTEMI E RETI · SICUREZZA INFORMATICA

Tipi di attacchi informatici

Conoscere come si attacca un sistema serve a una cosa sola: saperlo difendere.

LE PAROLE GIUSTE

Vulnerabilità, minaccia, attacco, rischio

Vulnerabilità

Una debolezza: un bug, una configurazione sbagliata, una password debole.

Minaccia

Chi o che cosa può causare un danno: un criminale, un malware, un guasto.

Attacco

L'azione concreta che sfrutta una vulnerabilità per causare un danno.

Rischio

Quanto è probabile l'attacco e quanto danno farebbe.

Ogni attacco che vediamo oggi **viola almeno uno** dei sei principi: riservatezza, integrità, disponibilità, autenticazione, autorizzazione, non ripudio.

MALWARE · SOFTWARE MALEVOLO

Cinque famiglie da riconoscere

Tipo	Come arriva	Che cosa fa	Viola
Virus	Si attacca a un file e parte quando lo apri	Infetta altri file, può danneggiarli	Integrità
Worm	Da solo, attraverso la rete	Si copia su altri computer senza nessun clic	Disponibilità
Trojan	Finge di essere un programma utile	Apre un accesso nascosto all'attaccante	Riservatezza, autorizzazione
Ransomware	Phishing, vulnerabilità, accessi deboli	Cifra i file e chiede un riscatto	Disponibilità
Spyware	Nascosto in app o estensioni	Registra ciò che fai e lo invia	Riservatezza

Molti malware moderni combinano più comportamenti: un trojan può installare uno spyware o un ransomware.

IL PIÙ TEMUTO DALLE AZIENDE

Come lavora un ransomware

1

Entra

Allegato di phishing, password debole, programma non aggiornato.

2

Si diffonde

Passa ad altri PC e server, cerca i backup collegati.

3

Cifra

I file diventano illeggibili, compare la richiesta di riscatto.

4

Ricatta

Spesso minaccia anche di pubblicare i dati rubati.

Viola la **disponibilità** e, con il furto dei dati, anche la **riservatezza**. Pagare non garantisce di riavere i file.

INGEGNERIA SOCIALE

Phishing: si attacca la persona, non il computer

Le forme

- **Phishing**: e-mail di massa che imitano banche, corrieri, scuole.
- **Spear phishing**: messaggio su misura per una persona precisa.
- **Smishing** e **vishing**: via SMS o telefonata.
- Falso supporto tecnico che chiede di installare un programma.

Le leve psicologiche

- **Urgenza**: "entro 24 ore".
- **Paura**: "il tuo account sarà bloccato".
- **Autorità**: "sono il dirigente", "sono la banca".
- **Curiosità** e **premi**: "hai vinto", "guarda chi ti ha taggato".

Obiettivo tipico: rubare le credenziali. Viola l'**autenticazione** e quindi la **riservatezza**.

AL COMPUTER · 15 minuti

Caccia agli indizi in una e-mail falsa

Da: Supporto Registro Elettronico <assistenza@registr0-elettronico.example>

Oggetto: URGENTE!! Il tuo account verra sospeso entro 24 ore

Allegato: Modulo_verifica.pdf.exe

Gentile utente, abbiamo rilevato un accesso sospetto. La tua password e scaduta. Per evitare la sospensione clicca qui e inserisci nome utente e password: https://registro.istituto.example/accedi

Cordiali saluti, lo staff tecnico

Passando il mouse sul link compare: http://login-verifica.example/registro.php

Apri un documento Google o Writer chiamato **phishing-Cognome**. Elenca ogni indizio sospetto e, per ciascuno, scrivi come lo verificheresti.

Controllo: gli indizi sono almeno 7. Guarda mittente, oggetto, allegato, saluto, ortografia, richiesta, link.

ATTACCHI ALLE PASSWORD

Tre modi per indovinare una password

1

Forza bruta

Si provano **tutte** le combinazioni possibili. Funziona sempre, ma può richiedere un tempo enorme.

2

Dizionario

Si provano parole comuni e varianti: `password`, `juventus1`, `Marco2008`.

3

Credential stuffing

Si riusano coppie e-mail e password rubate a **un altro sito**.

> Viola l'**autenticazione**. Il credential stuffing funziona solo perché tante persone usano la stessa password ovunque.

FACCIAMO I CONTI

Quanti tentativi servono con la forza bruta?

N = simboli possibili per carattere · L = lunghezza

$$\text{combinazioni} = N^{L}$$

PIN di 6 cifre

10^6 = 1.000.000 combinazioni

→ **un decimillesimo di secondo**

8 lettere minuscole

$26^8 \approx$ 209 miliardi di combinazioni

→ **circa 21 secondi**

Ipotesi di esempio: un attaccante con un archivio di password rubato prova 10 miliardi di combinazioni al secondo. Tempi nel caso peggiore.

AL COMPUTER · 20 minuti

Il foglio della forza bruta

	A	B	C	D	E	F
1	Tipo	N	L	Combinazioni	Secondi	Anni
2	8 minuscole	26	8	=POTENZA(B2;C2)	=D2/1E10	=E2/31536000

1. In Calc ricopia il foglio e aggiungi le righe: 6 cifre (10), 8 lettere e cifre (62), 8 con simboli (95), 12 minuscole (26), 12 con simboli (95).
2. Trascina in basso le formule di D, E, F. Salva come **forza-bruta-Cognome.ods**.

31.536.000 sono i secondi in un anno (365 · 24 · 3600).

Controllo: 12 caratteri con 95 simboli danno circa **1,7 milioni di anni**.

MAN-IN-THE-MIDDLE

Qualcuno si mette in mezzo alla conversazione

Tu

Ti colleghi alla rete "WiFi_Gratis_Stazione".

Attaccante

La rete è sua: vede e può modificare ciò che passa.

Il sito

Riceve le richieste e non si accorge di nulla.

- Viola la **riservatezza** (legge i dati) e l'**integrità** (li cambia).
- Si combatte con la **cifratura** delle comunicazioni: HTTPS, VPN.

> Se il browser avvisa che il **certificato non è valido**, fermati: potrebbe esserci qualcuno in mezzo.

DOS E DDOS

Troppe richieste: il servizio si blocca

DoS

Denial of Service: un'unica sorgente sommerge il servizio di richieste o sfrutta un difetto per mandarlo in crash.

DDoS

Distributed DoS: migliaia di dispositivi infetti (una **botnet**) attaccano insieme. Difficile da bloccare.

> Come mille telefonate finte a una pizzeria: i clienti veri non riescono a ordinare. Viola la **disponibilità**.

Le botnet sono fatte spesso di telecamere, router e altri oggetti connessi lasciati con la password di fabbrica.

ATTACCHI ALLE APPLICAZIONI WEB

SQL injection: i dati diventano comandi

```
# il cognome arriva da un modulo web
sql = "SELECT * FROM studenti WHERE cognome = '" + cognome + "'"
```

Si scrive Rossi

`... WHERE cognome = 'Rossi'`

La query funziona.

Si scrive D'Amico

`... WHERE cognome = 'D'Amico'`

L'apostrofo chiude il testo: errore.

Se un apostrofo cambia la query, chi attacca può aggiungere **pezzi di SQL** per leggere o cancellare dati. Viola **riservatezza** e **integrità**.

ATTACCHI ALLE APPLICAZIONI WEB

XSS: il testo diventa codice nel browser

Un sito di commenti mostra a tutti i visitatori il testo scritto dagli utenti, **così com'è**:

```
pagina += "<p>" + commento + "</p>"
```

Se qualcuno scrive `<b>Ciao</b>`, il commento appare in grassetto: il browser lo ha trattato come **HTML**.

Perché è grave

Allo stesso modo si può inserire uno **script**, che parte nel browser di chi legge: può rubare la sessione o cambiare la pagina.

Viola **riservatezza** e **integrità**.

AL COMPUTER · 15 minuti

Trova le righe vulnerabili

```
def cerca_studente(cognome):
    # cognome arriva da un modulo web
    sql = "SELECT nome, classe FROM studenti WHERE cognome = '" + cognome + "'"
    righe = db.execute(sql).fetchall()
    html = "<h3>Risultati per " + cognome + "</h3>"
    for nome, classe in righe:
        html += "<p>" + nome + " - " + classe + "</p>"
    return html
```

Apri Writer o Documenti Google e, nel file **codice-Cognome**, scrivi per ogni riga vulnerabile: numero, tipo di attacco, principio violato e che cosa succederebbe cercando `D'Amico`.

Controllo: le righe a rischio sono quelle in cui un dato scritto dall'utente viene incollato dentro un testo che poi è interpretato come codice.

ZERO-DAY

Una falla che nessuno ha ancora corretto

1

Il difetto esiste nel software, ma **nessuno lo sa**.

2

Un attaccante lo scopre e lo **sfrutta**.

3

Il produttore lo scopre e pubblica la **patch**.

4

Gli utenti **aggiornano**. Solo ora sono protetti.

"Zero giorni": il produttore ha avuto zero giorni per preparare una correzione. Può violare **qualsiasi** principio.

RIPASSO

Ogni attacco colpisce un principio

Attacco	Principio violato soprattutto
Ransomware, DoS e DDoS	Disponibilità
Spyware, man-in-the-middle	Riservatezza (e integrità)
Phishing, forza bruta, dizionario, credential stuffing	Autenticazione
Trojan con accesso nascosto	Autorizzazione
SQL injection, XSS	Riservatezza e integrità
Virus	Integrità
Zero-day	Qualsiasi, dipende dalla falla